

CMT 451 – Mobile Security

Module 4: Mobile Malware and Attack Techniques

Mobile Malware & Attack Techniques

CMT 451 — Mobile Security | Module 4

Understanding the evolving threats to mobile devices.



Slide 1: Module Context – Why Mobile Malware Matters

Key Points

- Mobile devices are now:
 - Banking terminals
 - Identity tokens
 - Corporate endpoints
- Attackers follow **money, data, and access**
- Mobile malware has evolved beyond “annoyance apps”

Learning Focus

- How mobile malware works
- How attackers bypass OS protections
- How defenders detect and mitigate attacks

Framework Mapping

- NIST CSF – Detect
 - OWASP MASVS – Resilience
-

Slide 2: Mobile Malware – Definition and Evolution

What Is Mobile Malware?

- Malicious software designed to:
 - Steal data
 - Spy on users
 - Gain persistent access
 - Monetize via fraud

Evolution Timeline

- SMS trojans → Banking trojans → Spyware → State-grade surveillance

Why Mobile Is Attractive

- Always on
- Always connected
- Always authenticated

Teaching Emphasis

A compromised phone ≈ compromised identity

Slide 3: Common Types of Mobile Malware

Major Categories

- **Trojans** – disguised as legitimate apps
- **Spyware** – silent surveillance
- **Ransomware** – device or data lockout
- **Adware** – aggressive monetization
- **Stalkerware** – intimate surveillance

Android vs iOS

- Android: broader attack surface
- iOS: fewer attacks, higher sophistication

Industry Reality

- Most infections start with **user action**
-

Slide 4: Mobile Malware Infection Vectors

Primary Entry Points

- Malicious apps (third-party app stores)
- Phishing (SMS, WhatsApp, email)
- Malicious SDKs
- Compromised websites
- Sideloaded applications

Critical Insight

- Users are often the weakest link
- Social engineering defeats technical controls

Case Example

- Fake mobile banking update via SMS link
-

Slide 5: Reverse Engineering & Malware Techniques

What Attackers Do

- Decompile mobile apps
- Bypass protections

- Modify app logic
- Repackage and redistribute

Common Techniques

- Code obfuscation
- Dynamic code loading
- Root / jailbreak detection evasion

Why This Matters

- Security is not just perimeter-based
 - Apps must defend themselves
-

Slide 6: Advanced Mobile Attack Techniques

Sophisticated Techniques

- Overlay attacks (credential capture)
- Accessibility abuse
- Keylogging
- Screen capture
- Command-and-control communication

Targeted Attacks

- High-value individuals
- Corporate executives
- Government officials

Teaching Emphasis

Not all malware is mass-market — some is precision-guided

Slide 7: Detection of Mobile Malware

Detection Approaches

- Signature-based detection
- Behavior-based detection
- Anomaly detection
- OS-level indicators

Limitations

- Zero-day malware
- Encrypted payloads
- Polymorphic code

Framework Mapping

- NIST CSF – Detect
 - Continuous monitoring is essential
-

Slide 8: Malware Mitigation and Defensive Controls

Preventive Controls

- App store vetting
- Secure OS configurations
- User awareness

Detective Controls

- Mobile threat defense (MTD)
- Log monitoring
- Behavioral analytics

Corrective Controls

- App revocation
- Device isolation
- Incident response

Key Message

No single control is sufficient

Slide 9: Role of Secure App Design (MASVS Resilience)

Developer Responsibilities

- Anti-tampering
- Runtime protection
- Secure storage
- Certificate pinning

OWASP MASVS Focus

- Resilience against reverse engineering

- Defense-in-depth

Industry Insight

- Mobile security must be **built-in**, not bolted-on
-

Slide 10: Key Takeaways & Examiner Focus

Key Takeaways

- Mobile malware is a **business risk**, not just a technical issue
- Users, apps, and OS controls must work together
- Detection and response are as important as prevention

Exam Focus

- Infection vectors
- Attack techniques
- Detection vs prevention
- Framework alignment (MASVS, NIST CSF)

Closing Thought

“In mobile security, trust must be continuously verified.”

Module 4 Quiz: Mobile Malware & Attack Techniques

SECTION A: QUESTIONS

Q1. Which statement BEST explains why mobile devices are attractive targets for malware?

- A. Mobile devices are cheaper than laptops
 - B. Mobile devices are always authenticated and carry sensitive data
 - C. Mobile operating systems have no security controls
 - D. Mobile devices are rarely connected to the internet
-

Q2. A malicious app disguised as a legitimate banking application is BEST described as:

- A. Adware
 - B. Worm
 - C. Trojan
 - D. Ransomware
-

Q3. Which infection vector MOST commonly introduces mobile malware?

- A. OS kernel updates
- B. Official app store security patches

- C. User installation of malicious apps or links
 - D. Encrypted device storage
-

Q4. Which mobile malware type is primarily designed for silent surveillance and data exfiltration?

- A. Ransomware
 - B. Adware
 - C. Spyware
 - D. Rootkit
-

Q5. Overlay attacks on mobile devices are primarily used to:

- A. Encrypt device storage
 - B. Capture user credentials by mimicking legitimate screens
 - C. Disable antivirus software
 - D. Patch OS vulnerabilities
-

Q6. Why is reverse engineering a serious concern for mobile application security?

- A. It improves application performance
 - B. It allows attackers to analyze and bypass security controls
 - C. It reduces application size
 - D. It prevents code obfuscation
-

Q7. Which technique helps mobile malware evade detection by traditional signature-based tools?

- A. Code signing
 - B. Polymorphism and dynamic code loading
 - C. Secure boot
 - D. Application sandboxing
-

Q8. Which control BEST aligns with the **Detect** function of the NIST Cybersecurity Framework?

- A. Secure coding practices
 - B. Mobile device encryption
 - C. Behavior-based malware detection
 - D. User access control policies
-

Q9. According to OWASP MASVS (Resilience), which control MOST improves resistance to reverse engineering?

- A. Certificate pinning
- B. Runtime application self-protection and obfuscation
- C. Cloud backup encryption
- D. Password complexity rules

Q10. Which statement BEST summarizes an effective defense strategy against mobile malware?

- A. Relying only on app store security
 - B. Eliminating user awareness training
 - C. Applying defense-in-depth across OS, apps, and users
 - D. Blocking all third-party applications
-
-

SECTION B: ANSWERS

A1. B – Mobile devices are always authenticated and carry sensitive data

A2. C – Trojan

A3. C – User installation of malicious apps or links

A4. C – Spyware

A5. B – Capture user credentials via fake screens

A6. B – Allows attackers to bypass security controls

A7. B – Polymorphism and dynamic code loading

A8. C – Behavior-based malware detection

A9. B – Runtime self-protection and obfuscation

A10. C – Defense-in-depth across OS, apps, and users

CMT 451 – Mobile Security

Question 1: Mobile Banking Malware Scenario

A mobile banking application reports multiple cases where customers claim funds were transferred without authorization. Investigation reveals that affected users had installed apps from unofficial app stores.

Required:

- a) Identify the **type(s) of mobile malware** likely involved.
 - b) Explain the **infection vectors** used by the attackers.
 - c) Describe **OS-level and application-level controls** that could have prevented the incident.
 - d) Recommend **immediate response actions** for the organization.
-

Question 2: Spyware and Privacy Violation Scenario

A journalist suspects that their smartphone is being monitored after confidential information appears in public forums. No obvious signs of compromise are visible.

Required:

- a) Explain how **mobile spyware** operates and remains undetected.
 - b) Identify **advanced attack techniques** likely used in such a case.
 - c) Describe **detection approaches** that could confirm the compromise.
 - d) Recommend **long-term mitigation and user protection measures**.
-

Question 3: Reverse Engineering and App Repackaging Scenario

A popular e-commerce mobile application is found circulating online as a modified version that steals customer login credentials.

Required:

- a) Explain how **reverse engineering and repackaging** enable this attack.
 - b) Identify **security weaknesses** in the original application design.
 - c) Describe **OWASP MASVS resilience controls** that should be implemented.
 - d) Explain how the organization can **protect users and restore trust**.
-

Question 4: Enterprise Mobile Malware Outbreak Scenario

An organization allows employees to use personal smartphones for work email and internal applications. Several devices become infected with malware that spreads through messaging apps.

Required:

- a) Explain why **BYOD environments** increase malware risk.
 - b) Identify **attack propagation techniques** used in mobile ecosystems.
 - c) Describe **detective and corrective controls** suitable for this environment.
 - d) Recommend **policy and technical controls** to prevent recurrence.
-

Question 5: Detection and Monitoring Failure Scenario

An organization deploys mobile threat defense tools but does not actively review alerts or logs. A malware incident goes unnoticed for weeks.

Required:

- a) Explain why this represents a **failure of detection**, not technology.
 - b) Identify **indicators of compromise** that should have been detected.
 - c) Describe how **continuous monitoring** aligns with the NIST CSF Detect function.
 - d) Recommend improvements to the **mobile security monitoring process**.
-

Question 6: Advanced Targeted Mobile Attack Scenario

A senior executive receives a seemingly legitimate SMS requesting an urgent app update. After installation, sensitive corporate data is leaked.

Required:

- a) Identify the **social engineering techniques** involved.
- b) Explain the **technical mechanisms** that enable such attacks.
- c) Describe **user-focused and technical controls** to mitigate this risk.
- d) Recommend **executive-level mobile security measures**.

